



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-42013 Gnutls: gnutls: certificate validation bypass due to oversized subject alternative name

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-42013 Gnutls: gnutls: certificate validation bypass due to oversized subject alternative name - Vulnerability Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-42013 Gnutls: gnutls: certificate validation bypass due to oversized subject alternative name

1. Executive Summary

CVE-2026-42013 is a certificate-validation flaw in GnuTLS where an oversized Subject Alternative Name (SAN) can cause hostname verification logic to skip SAN processing and incorrectly fall back to the certificate Common Name (CN). In practical terms, a remote adversary who can place a spoofed or attacker-controlled certificate in a victim's trust path may be able to satisfy a CN check even though SAN handling should have prevented fallback. The likely consequence is spoofing or adversary-in-the-middle activity against software that depends on vulnerable GnuTLS builds for TLS peer validation.

The issue is operationally important because GnuTLS is embedded in Linux distributions, middleware, service-to-service clients, package managers, appliances, reverse proxies, and custom applications. Exposure is highest where vulnerable Linux systems initiate or broker TLS sessions to high-value internal services, software repositories, or externally hosted APIs. This is not a vulnerability that automatically grants remote code execution; however, it can erode trust decisions in exactly the place defenders expect cryptographic identity checks to be reliable.

Public reporting reviewed for this assessment does not show confirmed in-the-wild exploitation or CISA KEV inclusion as of 2026-06-11. Severity treatment is uneven across sources: the upstream GnuTLS advisory classifies the issue as medium/certificate misuse, while NVD carries a Red Hat-supplied CVSS 3.1 score of 8.2 (High). Lost Boys Cyber assesses the issue as high-priority for patching on exposed Linux estates because exploitation is remote, impacts trust validation, and may enable stealthy traffic interception where an attacker already has certificate-positioning opportunities.

Immediate defender priorities are to identify assets with vulnerable GnuTLS packages, patch to upstream 3.8.13 or vendor backports, and add hunt coverage for vulnerable endpoints making TLS connections to sensitive destinations. Organizations with TLS interception, outbound proxying, update infrastructure, or internally hosted PKI-dependent services should prioritize validation because these environments amplify the business impact of certificate-verification bypasses.

2. Intelligence Requirement

This report answers the following intelligence requirement: what does CVE-2026-42013 change about trust validation in GnuTLS-based environments, which assets are most exposed, what evidence exists for active exploitation, and what actions should defenders take to reduce the likelihood and impact of certificate-spoofing or adversary-in-the-middle activity?

3. Source Review and Confidence

Source	Contribution	Confidence
GnuTLS advisory GNUTLS-SA-2026-04-29-8	Primary flaw description, upstream fix recommendation, reporter attribution, fixed upstream version 3.8.13	High
Debian Security Tracker / DSA-6281-1 / DLA-4595-1	Concrete vulnerable and fixed package versions across Debian releases	High
Ubuntu CVE page and USN-8284-1	Ubuntu package status, fixed versions, priority treatment, affected release scope	High
NVD JSON 2.0 record	Published date, Red Hat-supplied CVSS 3.1 vector 8.2, CWE mapping	High
MSRC Update Guide intake item	Discovery trigger and publication workflow only; limited technical depth	Low

The technical core of this assessment is well-supported by upstream advisory, patch, and distro tracker data. Confidence is lower on exploitation prevalence because reviewed public sources did not provide verified intrusion reporting, exploit

telemetry, or confirmed proof-of-concept weaponization. Where this report discusses probable attack paths, those judgments are analytic inferences derived from the certificate-validation behavior and common enterprise deployment patterns rather than from observed campaign data.

4.1 Vulnerability summary

Field	Value
CVE	CVE-2026-42013
Component	GnuTLS X.509 certificate hostname / email verification logic
Weakness	CWE-1284 - Improper Validation of Specified Quantity in Input
Upstream advisory	GNUTLS-SA-2026-04-29-8
Public description	Oversized SAN entries can cause verification to fall back to Common Name checks
Primary impact	Certificate validation bypass enabling spoofing or adversary-in-the-middle scenarios
NVD / Red Hat CVSS	8.2 High - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N
Upstream commit note	6.5 Moderate - CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N
Disclosure milestones	Upstream advisory 2026-04-29; NVD publication 2026-05-26; MSRC intake publication 2026-06-11
Exploitation status	No confirmed in-the-wild exploitation identified in reviewed public sources as of 2026-06-11

The upstream patch shows that the vulnerable code path treated an oversized SAN as a short-buffer condition and continued processing in a way that still permitted CN fallback. The fix explicitly disables CN or distinguished-name fallback when oversized SAN values are encountered, which aligns with RFC 6125 guidance that SAN processing should preclude CN fallback in these cases. That detail matters operationally: this is not just malformed-certificate handling, but a trust-decision error affecting identity verification semantics.

4.2 Why the flaw matters

Finding	Defensive implication
Exploitation is remote and targets TLS trust decisions	Any vulnerable client or middleware validating peer certificates over the network may be impacted
The bug affects certificate misuse, not code execution	Standard EDR exploit telemetry may be absent; asset inventory and TLS log analysis become more important
Attackers still need a certificate-positioning opportunity	Risk is highest where adversaries can intercept traffic, control DNS/network paths, or present trusted-but-misleading certificates
Severity is disputed across sources	Defenders should avoid dismissing the issue as merely theoretical; trust-bypass flaws often have outsized downstream impact
Vendor backports exist for major distros	Patch coverage can be measured and reduced quickly when package inventory is available

4.3 Affected versions and exposure indicators

Ecosystem / release	Vulnerable version observed	Fixed version observed	Notes
Upstream GnuTLS	Versions prior to 3.8.13	3.8.13+	Upstream advisory recommends 3.8.13 or later
Debian bullseye	3.7.1-5+deb11u5	3.7.1-5+deb11u10	Fixed via DLA-4595-1
Debian bookworm	3.7.9-2+deb12u6	3.7.9-2+deb12u7	Fixed via DSA-6281-1
Debian trixie	3.8.9-3+deb13u3	3.8.9-3+deb13u4	Fixed via DSA-6281-1
Debian forky / sid	Not listed as vulnerable in tracker	3.8.13-1	Fixed package available
Ubuntu 26.04 LTS	Not stated on page	3.8.12-2ubuntu1.1	Status: Fixed
Ubuntu 25.10	Not stated on page	3.8.9-3ubuntu2.2	Status: Fixed
Ubuntu 24.04 LTS	Not stated on page	3.8.3-1.1ubuntu3.6	Status: Fixed
Ubuntu 22.04 LTS	Not stated on page	3.7.3-4ubuntu1.9	Status: Fixed
Ubuntu 20.04 / 18.04 / 16.04 LTS	Needs evaluation	Needs evaluation	Reviewed page had not yet published fixed-state conclusions

4.4 Realistic attack scenarios

Scenario	Requirements	Likely outcome	Confidence
Adversary-in-the-middle against a vulnerable Linux client	Attacker can intercept network traffic and present a certificate crafted with oversized SAN content plus a CN matching the target hostname	Vulnerable client accepts the certificate when SAN processing should have prevented fallback	Medium
Compromised outbound proxy or hostile network enclave	Vulnerable appliance, middleware, or service mesh component validates upstream services using GnuTLS	Trust in upstream identity can be bypassed, allowing traffic inspection or credential theft	Medium
Internal service-to-service spoofing	Attacker gains network position inside a flat or weakly segmented environment and targets unpatched automation agents	Machine-to-machine TLS trust may be subverted, enabling lateral movement or secret interception	Medium

5. Threat Context

Reviewed public reporting does not currently show this CVE in CISA's Known Exploited Vulnerabilities catalog, and the sources reviewed for this report did not provide verified proof-of-exploitation or campaign reporting. That lowers immediate urgency relative to internet-scale RCEs, but it does not make the flaw low consequence. Certificate-validation bypasses are often chained with other realistic conditions such as DNS poisoning, proxy compromise, wireless interception, malicious internal routing, or unauthorized certificate issuance.

The adjacent GnuTLS advisory cluster published on 2026-04-29 included multiple certificate-validation and authentication issues. That clustering increases the likelihood that researchers and adversaries alike will review the affected code paths and test enterprise appliances or custom software that rely on GnuTLS. Environments that use Linux-based gateways, security tooling, agents, package retrieval, CI/CD connectivity, or OT/IoT management stacks should assume that opportunistic scanning and variant analysis are plausible even without public mass exploitation.

MITRE ATT&CK	Name	Relevance
T1557	Adversary-in-the-Middle	Most direct mapping: the flaw can enable acceptance of attacker-presented certificates during intercepted TLS sessions
T1584	Compromise Infrastructure	Plausible preparatory activity where an attacker acquires or controls infrastructure used to present spoofed services or relay traffic
T1199	Trusted Relationship	Relevant when the bypass is used against service-to-service trust paths, software repositories, or partner/API connections

Lost Boys Cyber judges the ATT&CK mapping above as contextual rather than evidentiary. The vulnerability itself does not prove a specific intrusion set or campaign, but it clearly supports adversary-in-the-middle and trusted-channel abuse when paired with network access or certificate-positioning opportunities.

6.1 Detection opportunities and limitations

This vulnerability does not produce a universal host artifact, registry key, or malware IOC. Detection therefore has to focus on three layers: exposure discovery (which hosts carry vulnerable GnuTLS packages), TLS anomaly telemetry (where certificate fields are suspicious or inconsistent), and environment-specific trust failures (which sensitive applications continue to use unpatched GnuTLS while making high-value TLS connections).

Detection objective	Data source	What to look for
Identify vulnerable assets	Vulnerability management / package inventory	Linux hosts with GnuTLS packages mapped to CVE-2026-42013 or versions below vendor-fixed builds
Spot suspicious certificate presentations	Zeek, proxy, TLS inspection, gateway logs	Large SAN fields, SAN parsing anomalies, hostname/CN mismatches, certificate-validation warnings
Prioritize likely impact	Network telemetry joined to asset inventory	Vulnerable hosts connecting to identity providers, package mirrors, secrets stores, CI/CD, or internal admin panels
Catch post-exploitation follow-on	Auth, proxy, and app logs	Unexpected credential reuse, session anomalies, or service impersonation after suspicious TLS activity

6.2 Exposure inventory query (Microsoft Defender XDR)

```
DeviceTvmSoftwareVulnerabilities
| where CveId == "CVE-2026-42013"
| summarize LastSeen=max(Timestamp) by DeviceId, DeviceName, OSPlatform, SoftwareName, SoftwareVersion,
VulnerabilitySeverityLevel, CveId
| order by LastSeen desc
```

6.3 Prioritized hunt for vulnerable systems making sensitive TLS connections

```
let vulnerable_devices =
  DeviceTvmSoftwareVulnerabilities
  | where CveId == "CVE-2026-42013"
  | distinct DeviceId, DeviceName, OSPlatform, SoftwareName, SoftwareVersion;
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (443, 8443, 9443)
| join kind=inner vulnerable_devices on DeviceId
| extend SensitiveDestination = case(
  RemoteUrl has_any ("login", "auth", "sso", "token", "vault", "repo", "git", "api"), "Likely
sensitive",
  RemoteIPType == "Private", "Internal TLS service",
  "General TLS")
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
SampleUrls=make_set(RemoteUrl, 10) by DeviceName, OSPlatform, SoftwareName, SoftwareVersion,
SensitiveDestination, InitiatingProcessFileName
| order by Connections desc
```

6.4 Pseudo-Sigma for TLS-inspection or Zeek-derived telemetry

```
title: Suspicious Oversized SAN Certificate Presented To Vulnerable Client Population
id: 8c2f3c7d-fd7e-4c7e-9c17-cve-2026-42013
status: experimental
description: |
  Detect certificates presented during TLS sessions where the SAN field is abnormally large,
  absent after parser failure, or inconsistent with hostname validation expectations. Tailor
  field names to Zeek, proxy, or TLS inspection products.
references:
  - https://www.gnutls.org/security-new.html#GNUTLS-SA-2026-04-29-8
  - https://nvd.nist.gov/vuln/detail/CVE-2026-42013
logsource:
  category: network_connection
  product: zeek
  service: ssl
  definition: Requires certificate metadata such as SAN length/count and CN/hostname fields

detection:
  oversized_san:
    san_length|gte: 2048
  hostname_fallback_pattern:
    server_name|exists: true
    certificate_subject_common_name|exists: true
  suspicious_outcome:
    tls_validation_result:
      - success
      - permitted
  condition: oversized_san and hostname_fallback_pattern and suspicious_outcome

falsepositives:
  - TLS inspection appliances that truncate certificate metadata
  - Non-standard internal PKI deployments with oversized SAN fields for legitimate reasons
level: high
tags:
  - attack.t1557
  - cve.2026-42013
```

6.5 Splunk hunt for anomalous certificate SAN size in Zeek SSL logs

```
index=zeek sourcetype=zeek:ssl earliest=-30d
| eval san_length=len(subject_alt_name)
| where san_length >= 2048 OR like(validation_status, "%fallback%")
| stats count min(_time) as first_seen max(_time) as last_seen values(server_name) as server_names
values(subject) as subjects values(subject_alt_name) as sans by id.orig_h id.resp_h issuer
validation_status
```

```
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

6.6 Hunting notes

- Prioritize vulnerable hosts that broker trust for other systems: proxies, API gateways, package mirrors, EDR relays, CI runners, and automation nodes.
- If your telemetry stack lacks SAN length fields, hunt for certificate-validation warnings, hostname mismatch events, or application-layer retry patterns after unusual TLS handshakes.
- No stable network or file IOCs are inherent to this vulnerability; defenders should not wait for IOC publication before patching.

7. Recommendations

Priority	Owner	Action	Rationale
Critical	Linux / platform engineering	Patch GnuTLS to upstream 3.8.13 or distro-fixed backports on internet-facing, proxying, and trust-brokering systems within 24-72 hours	Removes the vulnerable verification path on the highest-impact assets
High	Vulnerability management	Query for CVE-2026-42013 in asset inventory and track remediation by package version and business service	Converts an abstract CVE into a measurable exposure-reduction effort
High	Network / security engineering	Add hunts for vulnerable hosts making TLS connections to identity, secrets, package, and admin endpoints	Focuses limited triage time on systems where certificate-validation bypass matters most
Medium	PKI / application owners	Review whether custom applications explicitly rely on GnuTLS hostname validation and whether fallback behavior was assumed safe	Identifies edge cases where patching alone may not address trust-design weaknesses
Medium	Detection engineering	Implement the KQL and SIEM hunts in this report, then baseline for legitimate oversized SAN behavior	Improves early warning for attempted abuse or misconfiguration
Medium	Incident response	If suspicious TLS interception is suspected, collect proxy logs, Zeek SSL metadata, certificate chains, and affected client package versions before rotating credentials	Preserves evidence needed to validate whether trust bypass occurred

If patching is temporarily delayed, prioritize traffic segmentation, restrict outbound trust paths from vulnerable assets, and increase monitoring around TLS-interceptible workflows. Compensating controls do not eliminate the core validation flaw, but they can reduce the set of network positions from which an attacker could exploit it.

8. References

- 1. GnuTLS, "GNUTLS-SA-2026-04-29-8 / CVE-2026-42013," <https://www.gnutls.org/security-new.html#GNUTLS-SA-2026-04-29-8>

- 2. GnuTLS GitLab commit 29801bef00ecc0f23c0bac4cd333b269cd2c1af4, "x509: prevent fallback on oversized SAN," <https://gitlab.com/gnutls/gnutls/-/commit/29801bef00ecc0f23c0bac4cd333b269cd2c1af4>
- 3. Ubuntu Security, "CVE-2026-42013," <https://ubuntu.com/security/CVE-2026-42013>
- 4. Ubuntu Security Notice USN-8284-1, "GnuTLS vulnerabilities," <https://ubuntu.com/security/notices/USN-8284-1>
- 5. Debian Security Tracker, "CVE-2026-42013," <https://security-tracker.debian.org/tracker/CVE-2026-42013>
- 6. Debian DSA-6281-1, "gnutls28 security update," <https://security-tracker.debian.org/tracker/DSA-6281-1>
- 7. Debian DLA-4595-1, "gnutls28 security update," <https://security-tracker.debian.org/tracker/DLA-4595-1>
- 8. NVD JSON 2.0, "CVE-2026-42013," <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-42013>
- 9. Microsoft Security Response Center Update Guide, "CVE-2026-42013," <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-42013>